

4 Prevent Compromise of Credentials

4.1 Password Policy

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
<u>Control Definition</u> Control Objective: Ensure passwords are sufficiently resistant against common password attacks by implementing and enforcing an effective password policy. In-scope components: Passwords defined on the following components: - dedicated and general-purpose operator PCs - jump server - Swift-related components (including interfaces, GUI, Swift and customer (client) connectors, new HSM) - customer client connector - systems hosting Swift-related components - network devices protecting the secure zone or the customer client connectors - on-premises or remote (that is hosted or operated by a third party, or both) virtualisation or cloud platform hosting Swift-related VMs, including those hosting the Alliance Connect Virtual on Premises VPN, and their management PCs - personal tokens and personal mobile devices used as possession factor for multi-factor authentication (considered as software tokens) (see control 4.2) - bridging servers (such as middleware or file transfer servers other than customer connectors) used for and guardian of the secure data exchange between back-office and Swift-related components Risk Drivers: - password cracking, guessing, or other computational compromise <u>Implementation Guidance</u> Control Statement: All application and operating system accounts enforce passwords with appropriate parameters such as length, complexity, validity, and the number of failed login attempts. Similarly, personal tokens and mobile devices enforce passwords or a Personal Identification Number (PIN) with appropriate parameters. Control Context: Implementing a password policy that protects against common password attacks (for example, guessing and brute force) is effective for protecting against account compromise. Attackers often use the privileges of a compromised account to move laterally within an environment and progress the attack. Another risk is the compromise of local authentication keys to tamper with the integrity of transactions. However, it is important to recognise that passwords alone are generally not sufficient in the current cyber-threat landscape. Users should consider this control in close relationship with the multi-factor authentication requirement. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be						

considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives).

- A password policy that also covers PIN settings is established, aligned to current industry standards or industry best practices, and defines the following criteria:
 - password expiration
 - password length, composition, complexity, and other restrictions
 - password re-use
 - lock out after failed authentication attempts (and remedy)
 - password requirements modified as necessary for the following specific use cases:
 - in combination with a second factor (for example, one-time password)
 - authentication target (for example, operating system, application, mobile device, or token)
 - type of account (general operator, privileged operator, application-to-application account, or local authentication keys)

For additional best practice guidelines about password and PIN parameter settings, see the [Knowledge Base article 5021567](#) and [5022038](#).

- The password policy is developed in consideration of known password-based vulnerabilities in the computing environment. For example, requiring a password of 15 or more characters for Windows systems prevents Windows from computing the highly vulnerable LAN Manager (LM) password hash.
- The established password policy is enforced through technical means (for example, through an Active Directory group policy, or within application settings), when possible.
- Effectiveness of the password policy is reviewed regularly (annually, by recommendation).
- System settings related to password management and storage are aligned to industry and vendor best practices (for example, enabling the “NoLMHash” registry setting in Windows).
- Passwords used for secure zone systems are significantly more exposed if the passwords are stored in authentication systems outside of the secure zone (for example, an enterprise Active Directory). Instead, passwords for secure zone systems are, to the fullest extent possible, stored only within the zone (for example, in an Active Directory for production systems) as described in the guidance for the design of the secure zone or another existing secure zone that has similar controls.

Optional Enhancement:

- Apply the control to all bridging servers (such as middleware or file transfer servers other than customer connectors) used for data exchange between back-office and Swift-related components.

Note: Users should implement strong passwords and preferably strong authentication mechanisms for all systems used within the end-to-end transaction chain, and not limit these controls to the Swift infrastructure only.